



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Normativa de Ciberseguridad

TEMA 5

Normativa vigente de ciberseguridad de ámbito nacional e internacional.

Alberto Diéguez Álvarez

Tabla de contenido

1.- Descripción de la tarea.....	3
Caso práctico.....	3
Apartado 1: Marco Jurídico y Directiva NIS 2 (2,5 Puntos)	4
Apartado 2: Transición a ISO/IEC 27001:2022 (2,5 Puntos)	5
Apartado 3: Análisis de Continuidad y Resiliencia (Directiva CER y BIA) (2,5 Puntos)	6
Apartado 4: Esquema Nacional de Seguridad (ENS) (2,5 Puntos)	7

1.- Descripción de la tarea

Caso práctico



[isttic](#). Antena de Telecomunicaciones (CC BY-NC-SA)

Empresa: ACME S.A. (Proveedor de Servicios de Telecomunicaciones).

Contexto: ACME tiene 300.000 clientes particulares y empresariales. Es adjudicataria de los servicios de comunicaciones de las embajadas en España y proveedor de una gran entidad bancaria internacional.

Sede: Oficinas inteligentes inauguradas en 2020 con alta eficiencia energética y zonas de acceso público (parques).

Datos económicos para el análisis de impacto:

- SLA (Acuerdo de Nivel de Servicio) Clientes Empresa: Garantía del 99%. Compensaciones a partir de los 30 minutos de caída.
- Coste por interrupción: A partir de la primera hora de caída completa del servicio, las compensaciones ascienden a 500.000 € por cada hora adicional.
- Impacto en imagen: Se estima una pérdida fija de 200.000 € por incidente (pérdida de clientes y nuevas altas) independientemente de la duración, si el incidente se hace público.
- Apetito de riesgo: La organización establece que bajo ningún concepto puede asumir pérdidas superiores a 1,5 millones de euros en un solo incidente.

¿Qué te pedimos que hagas?

Como responsable de seguridad de ACME S.A., debes actualizar el plan de cumplimiento normativo para el año en curso, dado que han entrado en vigor nuevas directivas europeas y se han actualizado los estándares internacionales.

Apartado 1: Marco Jurídico y Directiva NIS 2 (2,5 Puntos)

ACME S.A. opera en el sector de las infraestructuras digitales y telecomunicaciones, y además provee servicios a la Administración Pública.

1. Identificación normativa: Enumera las 4 leyes o directivas principales (nacionales o europeas) que aplican obligatoriamente a ACME S.A. en materia de seguridad física y lógica.

1. Directiva (UE) 2022/2555 (NIS2), es una normativa europea que busca garantizar un nivel común de ciberseguridad en la UE.
2. ENS (Esquema Nacional de Seguridad). Al prestar servicios a la administración pública debe cumplir el ENS.
3. Directiva CER (sustituye a la Directiva de Infraestructuras Críticas 2008) la Directiva CER se ocupa de la seguridad física y la resiliencia ante amenazas no cibernéticas (desastres naturales, terrorismo físico, sabotaje).
4. RGPD (Reglamento General de Protección de Datos). Debe adecuar el tratamiento de datos a la exigencia del RGPD.

2. Clasificación NIS 2: Según la nueva Directiva (UE) 2022/2555 (NIS 2), ¿ACME S.A. se clasificaría como una Entidad Esencial o una Entidad Importante? Justifica tu respuesta basándote en los sectores afectados descritos en la adenda.

Se clasifica como una Entidad Esencial.

Dado que opera en una infraestructura digital crítica, presta servicios a la banca y a la administración pública, tiene gran impacto en la sociedad. Es decir, según la NIS2 estás serían las Entidades Esenciales: Energía, transporte, banca, salud, agua, administración pública, espacio.

3. Responsabilidad directiva: El CEO de ACME te pregunta qué le podría pasar a él personalmente si ignora las medidas de ciberseguridad bajo la nueva directiva NIS 2. Explícale brevemente las consecuencias para la dirección.

Actualmente la NIS2 introduce responsabilidades directas a la alta dirección. Es decir, los directivos pueden ser personalmente responsables si no aseguran el cumplimiento de las medidas de ciberseguridad, llegando incluso a inhabilitación temporal para casos graves.

Apartado 2: Transición a ISO/IEC 27001:2022 (2,5 Puntos)

El cliente bancario de ACME exige que la certificación de seguridad se actualice a la versión ISO/IEC 27001:2022.

1. Nueva estructura: Explica brevemente cómo ha cambiado la estructura de los controles del Anexo A (comparando la versión 2013 con la 2022).
¿Cuáles son los 4 nuevos "Temas" en los que se agrupan los controles?

Los 4 nuevos temas de controles son:

1. Organizacionales: 37 controles (políticas, roles, inteligencia de amenazas...).
2. Personas: 8 controles (trabajo remoto, concienciación, confidencialidad...).
3. Físicos: 14 controles (seguridad de oficinas, mantenimiento, monitoreo...).
4. Tecnológicos: 34 controles (autenticación, malware, redes, cifrado...).

2. Selección de controles nuevos: De los 11 nuevos controles introducidos en la versión 2022, selecciona DOS que sean críticos para ACME S.A. y justifica su elección basándote en el caso práctico (ej. su actividad internacional, el uso de servicios en la nube, etc.).

Nota: Debes indicar el nombre del control y por qué aplica al caso.

Entre los 11 nuevos controles, me quedaría con:

1. Inteligencia de amenazas: Para poder identificar y anticiparnos, dado que trabajamos con entidades de alto valor, se necesita una buena protección de amenazas.
2. Seguridad en la nube: Al prestar servicios de comunicaciones se debe proteger los servicios y los datos almacenados en la nube.

Apartado 3: Análisis de Continuidad y Resiliencia (Directiva CER y BIA) (2,5 Puntos)

1. Directiva CER: Dado que ACME tiene una sede física crítica y provee servicios esenciales, la nueva Directiva CER (resiliencia de entidades críticas) le aplica. A diferencia de la NIS 2, ¿de qué tipo de amenazas debe protegerse ACME para cumplir con la CER? Pon un ejemplo basado en la descripción de su sede (jardines, acceso público, etc.).

Dado que la directiva CER se basa en amenazas físicas y no cibernéticas, por ejemplo, como desastres naturales... Para el ejemplo de ACME las zonas de acceso público (parques), la alta dependencia de tecnología y las oficinas inteligentes deben protegerse frente amenazas físicas, por ejemplo: Tener parques abiertos al público aumenta el riesgo de intrusión o sabotaje, una persona podría entrar y dañar los sistemas.

2. Cálculo de parámetros BIA: Realiza el análisis de impacto basándote en los datos económicos proporcionados:

- **Calcula el coste total del incidente si el servicio cae durante 1 hora, 2 horas y 3 horas.**

Basándonos en el coste por interrupción y el impacto reputacional de imagen, calculamos:

- 200.000 € por incidente.
 - 500.000 € a partir de la primera hora de caída completa.
-
- 1 hora: 200.000 € por incidente
 - 2 horas: 700.000 €, el incidente más una hora a mayores de la primera.
 - 3 horas: 1.200.000 €, el incidente más dos horas a mayores de la primera.

- **Determina el MTPD (Tiempo Máximo Tolerable de Interrupción) exacto antes de superar el límite de pérdidas de 1,5 millones de euros.**

En el ejemplo anterior vimos el coste de 3 horas (1.200.00 €), si asciende a 4 horas sería de 1.700.00 €, lo que superaría el MTPD, entonces podemos decir que el MTPD es de 3 horas

- **Propón un RTO (Objetivo de Tiempo de Recuperación) lógico para este escenario.**

Obviamente el RTO tiene que ser menor que el MTPD para tener un margen de seguridad, propondría un RTO de menos de 2 horas, para tener un margen de seguridad y evitar grandes pérdidas.

Apartado 4: Esquema Nacional de Seguridad (ENS) (2,5 Puntos)

ACME presta servicios a las embajadas, lo que implica tratar información clasificada o sensible de la Administración Pública.

1. Categorización del sistema: Determina la categoría del sistema (Básica, Media o Alta) según el ENS. Para ello, valora las dimensiones de Confidencialidad y Disponibilidad para el servicio de las embajadas. Justifica por qué asignas ese nivel a cada dimensión (piensa en el impacto de que se filtren comunicaciones diplomáticas o que estas se corten).

Dado que se manejan comunicaciones con la embajada, serían comunicaciones sensibles así que la determinaría de categoría ALTA, es decir:

- Confidencialidad: ALTA, dado que se manejan comunicaciones sensibles con organizaciones públicas internacionales.
- Disponibilidad: ALTA, dado que una interrupción afectaría a los servicios de la comunicación del Estado.

2. Declaración de aplicabilidad: Si el sistema resulta ser de categoría MEDIA o ALTA, ¿es suficiente con aplicar los controles básicos? ¿Qué tipo de auditoría externa debería pasar ACME cada dos años según el ENS para mantener la conformidad?

No sería suficiente solo con aplicar los controles básicos dado que ACME al trabajar con embajadas por ejemplo el impacto de cualquier incidencia es alto.

Según el capítulo 4 del ENS Seguridad de sistemas: auditoría, informe e incidentes de seguridad, establece los requisitos de auditoría de seguridad de la organización. Luego en el Anexo III del ENS se especifica la auditoría de seguridad.

The screenshot displays a web application interface. On the left, a document viewer shows 'Disposición 7191 del BOE núm. 106 de 2022' at 85% zoom. The document content is titled 'ANEXO III Auditoría de la seguridad' and includes sections 1.1 and 1.2 detailing security audit requirements. On the right, a sidebar shows the user profile for 'ALBERTO DIEGUEZ ALVAREZ' with an 'Editar perfil' button. Below the profile, 'Información Personal' includes email and city. 'Detalles del curso' lists 'Perfiles de curso' such as 'Análisis Forense Informático (25-26)' and 'Incidentes de Ciberseguridad (25-26)'.

Webgrafía:

- <https://ciberso.com/blog/gobierno-de-la-ciberseguridad/directiva-nis-2-un-marco-coordinado-para-reforzar-la-ciberseguridad-en-europa/>
- <https://www.ccn-cert.cni.es/en/pdf/guias/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/502-ccn-stic-802-auditoria-del-ens/file.html>
- <https://www.boe.es/boe/dias/2022/05/04/pdfs/BOE-A-2022-7191.pdf>